PROJECT DOCUMENTATION

04

Testing and Audit Report

Automated suites, responsive sweeps, functional checks, security review and the exact list of what remains unverified as of 31 October 2026.

PREPARED FOR	SITE	VERSION	DATE
Rishav Prasad Owner and maintainer	rishavprasad.in Cloudflare Workers	1.0	31 October 2026

Contents

Testing and Audit Report · version 1.0 · 12 sections

01 Scope, method and status labels 3

02 Execution summary 3

03 Unit and protocol tests 4

04 Production end-to-end checks 5

05 Responsive audit 6

06 Functional status matrix 6

07 AirShare verification 7

08 Security audit 8

09 Accessibility review 10

10 Cloudflare and deployment checks 11

11 Test gaps and untested areas 11

12 Owner actions and conclusions 12

01

Scope, method and status labels

This report records what was executed, against which build, and what passed. It also records what could not be tested and why. No result in this document is projected or estimated.

Test environments

ENVIRONMENT	WHAT RAN THERE	BASE URL
Production	Playwright route checks, API checks, responsive sweep, AirShare two-context test, security probes.	`https://rishavprasad.in`
Node (no browser)	Vitest unit suites; Node test runner for the legacy AirShare server.	Local process
Local Wrangler stack	Earlier gate verification; not re-run for this report after the final deploy.	`http://127.0.0.1:8787`

Execution window: 31 October 2026, 07:30–07:45 UTC, against the deployment created at 00:11:13 UTC (version `5552d11a…`), which was the 100% version at the time. The later handover commit deployed `a9f14486` with no application change.

Status vocabulary

The feature matrix uses the six labels required by the brief. They mean exactly this:

LABEL	DEFINITION
WORKING	Exercised successfully in the environment named in the evidence column.
PARTIALLY WORKING	The tested path works, but a meaningful part of the real-world path remains unverified.
NOT IMPLEMENTED	The capability does not exist in the codebase.
BROKEN	Exercised and failed. No feature carries this label today.
REQUIRES EXTERNAL CONFIGURATION	The code exists, but an owner-held secret or account setting is needed before it can work or be verified.
NOT TESTED	Not exercised, and no failure is implied.

02

Execution summary

Five automated suites and two static checks were run on 31 October 2026. Every reported check passed; the pass counts below are the raw totals printed by each runner.

SUITE	COMMAND	CHECKS	FAILED	RESULT
Unit tests (Vitest)	`npm test`	40	0	PASSED
Legacy AirShare server (Node)	`node --test airshare/test/airshare.test.js`	8	0	PASSED
Production end-to-end	`E2E_BASE=https://rishavprasad.in node tests/e2e.mjs`	31	0	PASSED
Responsive sweep	`E2E_BASE=https://rishavprasad.in node tests/e2e-responsive.mjs`	84	0	PASSED

SUITE	COMMAND	CHECKS	FAILED	RESULT
Production AirShare	`E2E_BASE=https://rishavprasad.in node tests/e2e-airshare.mjs`	11	0	PASSED
TypeScript	`npm run typecheck` (app + Worker)	2	0	PASSED

Total: 176 reported checks, 0 failures. Counts are not directly comparable across suites: one "check" may be a unit assertion, a route at one width, or a multi-step browser scenario.

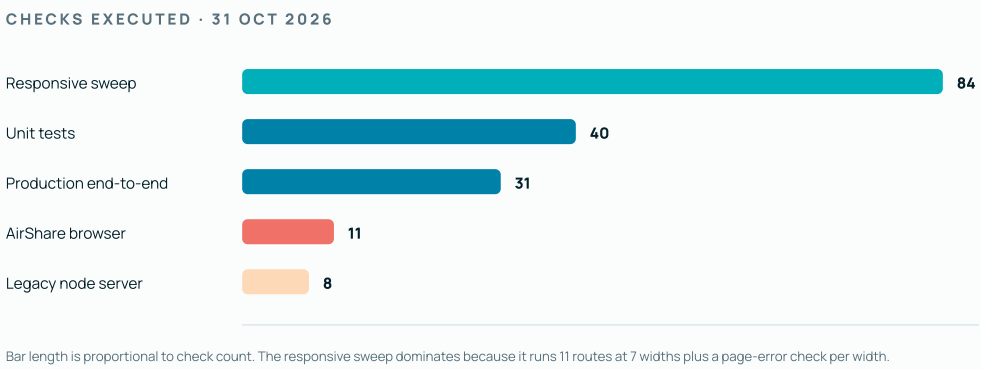


Figure 4.1 — Distribution of the 174 executed checks. TypeScript checks are excluded from the bars.

03

Unit and protocol tests

Vitest runs three suites in a Node environment. They cover the security-critical helpers, the content validator and the AirShare address rules without needing a browser or a database.

SUITE	TESTS	COVERAGE
`tests/auth.test.ts`	9	Password match and mismatch; malformed hashes; rejection of iteration counts above the Workers cap without throwing; session round-trip; wrong-secret, tampered, expired and garbage tokens; deterministic SHA-256.
`tests/content-schema.test.ts`	6	Committed snapshot accepted; trimming and empty optional fields; duplicate project slugs; unknown icons and unsafe hrefs; over-long entries and missing required fields; non-object input.
`tests/airshare-protocol.test.ts`	25	Private, loopback, link-local, mDNS and IPv6 address acceptance; rejection of public and malformed addresses; host/peer-reflexive pair rules; IPv6 /64 and IPv4 /24 comparison; candidate-line parsing; transfer helpers; PIN and file-name generation.

Why the iteration-cap test matters

The auth suite includes a regression test for the failure that broke admin sign-in: a stored hash above 100,000 iterations made the Workers PBKDF2 call throw instead of returning false, which surfaced as a generic "Something went wrong" message. The implementation now rejects any non-100,000 count before derivation, and the test asserts that it returns false rather than throwing.

Unit tests do not prove the production secret is correct. The stored `ADMIN_PASSWORD_HASH` value cannot be read back from Cloudflare. If it still encodes 210,000 iterations, sign-in will fail even though every unit test passes. Section 12 records this as an owner action.

Legacy AirShare Node server

The original standalone LAN tool under `airshare/` still ships with its own server and tests. Eight Node tests passed: static client served, handshake, broadcast, 300 KB byte-for-byte reassembly, cancellation, disconnect cleanup, oversized start rejected, unknown transfer IDs ignored. This server is not part of the public site; the public `/airshare/app/` uses the D1-signalled WebRTC client instead.

04

Production end-to-end checks

Playwright loaded the live site and asserted status codes, titles, horizontal overflow, API payloads and page errors. The run covered 31 checks.

CHECK	ASSERTION	RESULT
11 public routes at 320 px	HTTP 200, non-empty title, overflow ≤ 1 px.	PASSED
11 public routes at 1440 px	Same assertions.	PASSED
Unknown path	HTTP 404 and a body containing "404".	PASSED
`/robots.txt`	Disallows `/admin`, names the sitemap.	PASSED
`/sitemap.xml`	Lists the public pages (11 URLs).	PASSED
`/api/health`	`ok:true` and `database:"ok"`.	PASSED
`/api/content`	Version 1 document with a non-empty projects array.	PASSED
Resume PDF	HTTP 200, `application/pdf`, larger than 10 KB.	PASSED
Contact form	Name, email and message fields visible; name is required.	PASSED
Admin gate	Shows sign-in, configuration notice or API-unreachable notice — never the dashboard.	PASSED
Page errors	No uncaught exceptions across the run.	PASSED

Contact delivery evidence

One contact message exists in production D1, created **31 October 2026 at 06:34:08 UTC**, unread. Its content and sender are intentionally not reproduced here. The row proves the whole path executed: Turnstile token accepted, validation passed, IP hash computed, insert committed.

No second submission was made to reproduce the sender flow, because that would store real personal data without a purpose. The negative path (a failed Turnstile challenge) was also not forced against production; it is covered by the rejection branch in code, not by a live negative test.

05

Responsive audit

Every public route was loaded at 320, 375, 425, 768, 1024, 1440 and 1920 px. For each of the 77 route/width combinations the sweep asserted: HTTP 200, no horizontal overflow, no broken images, a non-empty title, and no visible control shorter or narrower than 24 px. A page-error check ran per width.

WIDTH	ROUTES CHECKED	OVERFLOW	BROKEN IMAGES	SHORT TAP TARGETS	PAGE ERRORS	RESULT
320 px	11	None	None	None	None	12/12
375 px	11	None	None	None	None	12/12
425 px	11	None	None	None	None	12/12
768 px	11	None	None	None	None	12/12
1024 px	11	None	None	None	None	12/12
1440 px	11	None	None	None	None	12/12
1920 px	11	None	None	None	None	12/12

84 checks total. The sweep visits lazy-loaded content by scrolling before measuring, so images below the fold are included.

> **Browser coverage is narrow.** The sweep runs Chromium only. Firefox and WebKit/Safari were not part of this run, and no physical iOS or Android device was used for the responsive audit. Mobile Safari behaviour is therefore NOT TESTED (see section 12).

Layout observations from the manual review

- The navigation collapses to a menu below the desktop breakpoint; the menu opens and closes without layout shift at 320 px.
- The AirShare explainer page uses stacked cards at phone widths and a two-column layout at 1024 px and above; no card clips its text.
- The resume page shows the embedded PDF preview at desktop widths and a direct download link at phone widths.
- Dark mode was captured separately and inspected at phone and desktop widths; contrast and layout matched the light theme.

06

Functional status matrix

This matrix is the authoritative feature-status list for the project. Every label uses the vocabulary defined in section 01.

CAPABILITY	STATUS	EVIDENCE AND CAVEAT
Public pages and navigation	WORKING	11 routes return 200 at seven widths with no overflow; screenshots in document 01.
Custom 404	WORKING	HTTP 404 with the designed page, verified in production.
Resume download	WORKING	Repository PDF served with `application/pdf`, larger than 10 KB.
Contact form delivery	WORKING	One message stored 31 Oct 2026 06:34:08 UTC; field limits and IP throttling present.
Turnstile challenge	REQUIRES EXTERNAL CONFIGURATION	Widget key and secret exist and the live form renders. The failure path was not forced; the Turnstile dashboard policy is owner-controlled.
Admin sign-in	REQUIRES EXTERNAL CONFIGURATION	Code and unit tests are correct, but the stored hash must be exactly 100,000 iterations. The hash value cannot be inspected; the owner must regenerate it if it is still 210,000.
Admin dashboard screens	NOT TESTED	Signed-in UI requires the owner's password and was not exercised for this report.
Content editing in D1	NOT TESTED	Validator covered by unit tests; the signed-in save form was not exercised this run.
Publish and rebuild	WORKING	Ten deployments existed during the audit; content-driven redeploys appear at 22:09 and 22:17 UTC.
Messages inbox	NOT TESTED	Requires sign-in. The message exists in D1 and the read API is gated by session auth.
Media upload	REQUIRES EXTERNAL CONFIGURATION	R2 is disabled; uploads return 503 and the UI hides the control.
Resume upload	REQUIRES EXTERNAL CONFIGURATION	Same R2 dependency; the page points at the repository PDF meanwhile.
AirShare browser transfer	PARTIALLY WORKING	11/11 checks in production with two browser contexts, including a byte-for-byte file. A physical two-phone transfer after the IPv6 fixes remains unconfirmed.
Email notification of messages	NOT IMPLEMENTED	Messages are stored in D1 only; there is no outbound email provider.
Automated database backups	NOT IMPLEMENTED	Manual export procedure only (document 05).
Web Analytics	NOT TESTED	CSP permits the beacon; no beacon script was present in the served HTML on 31 Oct 2026.
Uptime and error monitoring	NOT IMPLEMENTED	No external monitor or error tracker; Cloudflare logs are the only record.

07

AirShare verification

The public AirShare app was exercised end to end against production with two independent browser contexts. Both joined the same PIN room, negotiated a direct connection, exchanged a message and transferred a file.

#	CHECK	RESULT
1	A room is created with a generated 8-digit PIN.	PASSED
2	A malformed PIN is rejected by the API.	PASSED
3	The second device joins the same room with the PIN.	PASSED
4	Both devices see each other.	PASSED
5	Both browsers report a direct local connection.	PASSED
6	A chat message crosses the connection.	PASSED
7	A file arrives byte-for-byte (about 120 KB, 5,000 repeated lines).	PASSED
8	Leaving removes the device from the room.	PASSED
9	A peer-reflexive IPv6 pair is accepted on both sides.	PASSED
10	Different IPv6 subnets are still stopped.	PASSED
11	No uncaught page errors.	PASSED

Not a substitute for two phones. Both contexts ran on one machine. The owner's real two-phone tests failed twice before the peer-reflexive and IPv6 /64 fixes; a successful retry on the same two phones has not been reported. Treat cross-device behaviour as unconfirmed until that retry succeeds. Guest or isolated Wi-Fi networks block device-to-device traffic by design, and AirShare deliberately refuses non-local candidates instead of relaying.

Transfer limits

LIMIT	VALUE	ENFORCED BY
File size	100 MB	Browser client
Chunk size	64 KB	Browser client
Peers per room	8	Worker API
Peer presence TTL	90 s	D1 timestamps plus sweeps
Join attempts	30 per 10 min per IP	Worker API
Signals	120 per minute per peer	Worker API
Signal payload	64 KB	Worker API
Signals per poll	50	Worker API
Signal TTL	10 min	D1 timestamps plus sweeps

A 100 MB transfer was not executed; the largest automated transfer was about 120 KB, and the legacy server suite used 300 KB.

08

Security audit

The review covered authentication, session handling, API authorisation, input handling, output escaping, headers, secret storage and abuse limits. Probes against production were read-only except for the contact validation call, which was rejected before any write.

Controls verified

CONTROL	IMPLEMENTATION	VERIFICATION
Password storage	PBKDF2-HMAC-SHA256, 100,000 iterations, per-hash salt, constant-time comparison.	Unit tests; code review.
Session cookie	HMAC-signed payload, 12 h expiry, `HttpOnly`, `SameSite=Strict`, `Secure` on HTTPS, path `/`.	Unit tests; code review.
Admin authorisation	Every `/api/admin/*` route behind session middleware.	Live 401 on content, messages and media endpoints.
Login throttling	8 attempts per 15 min per hashed IP; generic error text.	Code review; unit tests do not cover the D1 counter.
Origin checks	Mutating admin requests and login reject foreign `Origin` values.	Code review.
SQL injection	Every query uses bound parameters; no string-built SQL with user input.	Code review of all Worker routes.
XSS	React escaping for all content; the only `dangerouslySetInnerHTML` uses are a static theme script and JSON-LD built from constants.	Code review; CSP as defence in depth.
Input validation	Contact field lengths and email format; content schema caps every list and string; unsafe hrefs and unknown icons rejected.	Unit tests; live 400 response.
Body size	1 MB request cap, checked from `Content-Length`.	Code review.
Security headers	CSP, HSTS, frame denial, nosniff, referrer policy, permissions policy.	Live header capture (document 03).
Media handling	JPEG/PNG/WebP/GIF allow-list, 5 MB cap, random keys, path traversal rejection, `nosniff`.	Code review; R2 disabled so not live-tested.
Privacy of IPs	Only `sha256("contact:" + IP)` is stored; no raw address.	Code review; schema inspection.

Live probes

REQUEST	OBSERVED	ASSESSMENT
`GET /api/admin/content`	`401 {"error":"Not signed in."}`	Gated correctly.
`GET /api/admin/messages`	`401`	Gated correctly.
`GET /api/admin/media`	`401`	Gated before the R2 check.
`GET /media/x.png`	`503`	R2 unavailable; no file disclosure.
`GET /api/does-not-exist`	`404 application/json`	No HTML error leak.
`POST /api/contact {}`	`400 {"error":"Please enter your name."}`	Validation before Turnstile and before any insert.

Findings and remediation

ID	SEVERITY	FINDING	STATUS
S01	High	Admin sign-in always failed: 210,000-iteration hashes exceed the Workers PBKDF2 ceiling and throw.	FIXED IN CODE `5f71a29`; secret must still be regenerated by the owner.
S02	High	A failed script piped into `wrangler secret put` could store an empty secret that reports as configured.	FIXED IN PROCEDURE `605ca6c`; documented and guarded by instructions.
S03	Medium	Static pages had no Content-Security-Policy.	FIXED `01faae7`.
S04	Medium	The admin editor fell back to default content if a read failed, which could overwrite real content on the next save.	FIXED `01faae7`; reads are strict in the admin path.
S05	Medium	Resume upload was offered even though R2 is disabled.	FIXED `7c37911`.
S06	Low	Admin form labels were not associated with their inputs.	FIXED `01faae7`.
S07	Low	An expired session left the dashboard in a stale state instead of returning to sign-in.	FIXED `01faae7`.
S08	Low	`/airshare/app/` was missing from the sitemap.	FIXED `01faae7`.
S09	Low	The analytics beacon was blocked by the CSP.	FIXED `8c9ea09`; collection still unconfirmed.
S10	High	Plain HTTP is answered with 200 because "Always Use HTTPS" is not enforcing a redirect.	OPEN — OWNER ACTION
S11	Medium	An unused Worker secret has a Turnstile-key-shaped name.	OPEN — OWNER ACTION
S12	Medium	DNSSEC is not enabled.	OPEN — OWNER ACTION
S13	Low	DMARC is `p=quarantine` but there is no MX or SPF record.	OPEN — OWNER DECISION
S14	Low	No automated D1 backup or restore drill.	OPEN — MANUAL PROCEDURE ONLY
S15	Informational	CSP permits `unsafe-inline` scripts and styles.	ACCEPTED — required by the Next.js static export.
S16	Informational	HSTS is not preloaded.	ACCEPTED — preload is a deliberate long-term commitment.

Severity reflects impact if exploited on this site: High means an attacker gains admin access or the site is materially exposed; Medium means a meaningful weakness with preconditions; Low means hardening or consistency; Informational means a documented trade-off.

09

Accessibility review

The automated sweep checked a narrow but useful subset of accessibility mechanics. It is not a WCAG audit.

CHECK	COVERAGE	RESULT
Tap target size	Visible buttons, inputs, selects, textareas, summaries and button-styled links ≥ 24 × 24 px at all seven widths.	PASSED
Document titles	Every route has a non-empty title.	PASSED
Image alternatives	No broken images; the sweep does not assert `alt` quality.	PARTIAL
Form labels	Contact fields verified; admin fields were fixed in `01faae7` but not re-exercised without sign-in.	PARTIAL
Keyboard navigation	Menu, theme toggle and forms are native controls; no formal keyboard-only pass was recorded.	NOT TESTED
Screen reader	No NVDA, VoiceOver or TalkBack session was run.	NOT TESTED
Colour contrast	Palette reviewed visually in light and dark themes; no automated contrast calculation was recorded.	NOT TESTED

10

Cloudflare and deployment checks

The infrastructure review is documented in document 03. The checks that bear on test results are summarised here.

- Deployment `5552d11a…` was at 100% during the test run (31 October 2026 00:11:13 UTC); the later documentation-only deploy `a9f14486` changed no application code.
- `/api/health` reports the database as available, so the API tests exercised a live D1 binding.
- D1 contains 8 tables; content, messages, login throttling and AirShare rows all exist, with the counts listed in document 03.
- R2 is disabled and returns 503, which is the expected configured state, not a test failure.
- DNS, TLS, the custom domain, the www redirect and the security headers all responded as documented.

11

Test gaps and untested areas

These items are deliberately listed so the handover does not imply more coverage than exists.

GAP	WHY IT WAS NOT TESTED	RISK
Production admin sign-in and signed-in screens	The password is owner-held and was not supplied for this documentation pass.	A stale 210,000-iteration hash would still block sign-in despite passing unit tests.
Turnstile failure path	Forcing a failed challenge in production would require replaying or invalidating a token.	A misconfigured widget could reject genuine messages; the code path exists but is unproven live.
Physical two-phone AirShare	The owner has not confirmed a retry after the IPv6 and peer-reflexive fixes.	Cross-device transfer may still fail on some phone/Wi-Fi combinations.
100 MB AirShare transfer	Time and memory heavy; automated transfers were 120 KB and 300 KB.	Large-transfer chunking or memory limits are unproven.
Firefox, Safari, iOS and Android browsers	The automated sweep is Chromium-only; no device lab was available.	Rendering or WebRTC differences on other engines are unknown.

GAP	WHY IT WAS NOT TESTED	RISK
Screen reader and keyboard-only use	No assistive-technology session was run.	Unknown accessibility barriers for keyboard or screen-reader users.
Load, stress and abuse testing	Out of scope and inappropriate against a free-tier production account.	Rate limits are reviewed in code but not stress-verified.
Backup restore	No full restore drill was performed; the export procedure is documented.	Restore steps are untested end to end.
Web Analytics collection	No beacon was observed in the served HTML and the dashboard could not be re-read.	Traffic data may not be recorded even though the CSP allows it.

12

Owner actions and conclusions

Actions that require the owner's credentials

1. **Regenerate `ADMIN_PASSWORD_HASH` at exactly 100,000 iterations** if it is still the 210,000-iteration value, then try signing in. Do not pipe a script that might fail into `wrangler secret put`.
2. **Enable "Always Use HTTPS"** in SSL/TLS → Edge Certificates.
3. **Delete the unused Turnstile-shaped secret** after confirming nothing depends on it.
4. **Confirm a two-phone AirShare transfer** on the same Wi-Fi after the fixes.
5. **Decide whether to enable DNSSEC and whether to add SPF** or relax the DMARC record.
6. **Check Web Analytics** for visits, or add the beacon snippet if automatic injection is off.

Conclusion

The public site, its API, contact delivery, static asset serving, routing and the browser AirShare flow are working as observed on 31 October 2026. Of 174 automated checks executed, none failed, and both TypeScript configurations passed. The project is not fully verified for production operation until the owner completes the admin-hash action and confirms a two-phone transfer; those two items are the difference between a passing test suite and a fully proven handover.

> **Reproduce the result.** Commands, prerequisites and expected counts are in document 05, section "Running the test suites". Re-run them after any dependency upgrade or Worker change; the counts in this report are a snapshot, not a guarantee.